

Solution brief

Verified mitigation for the post-Mythos zero-day clock.

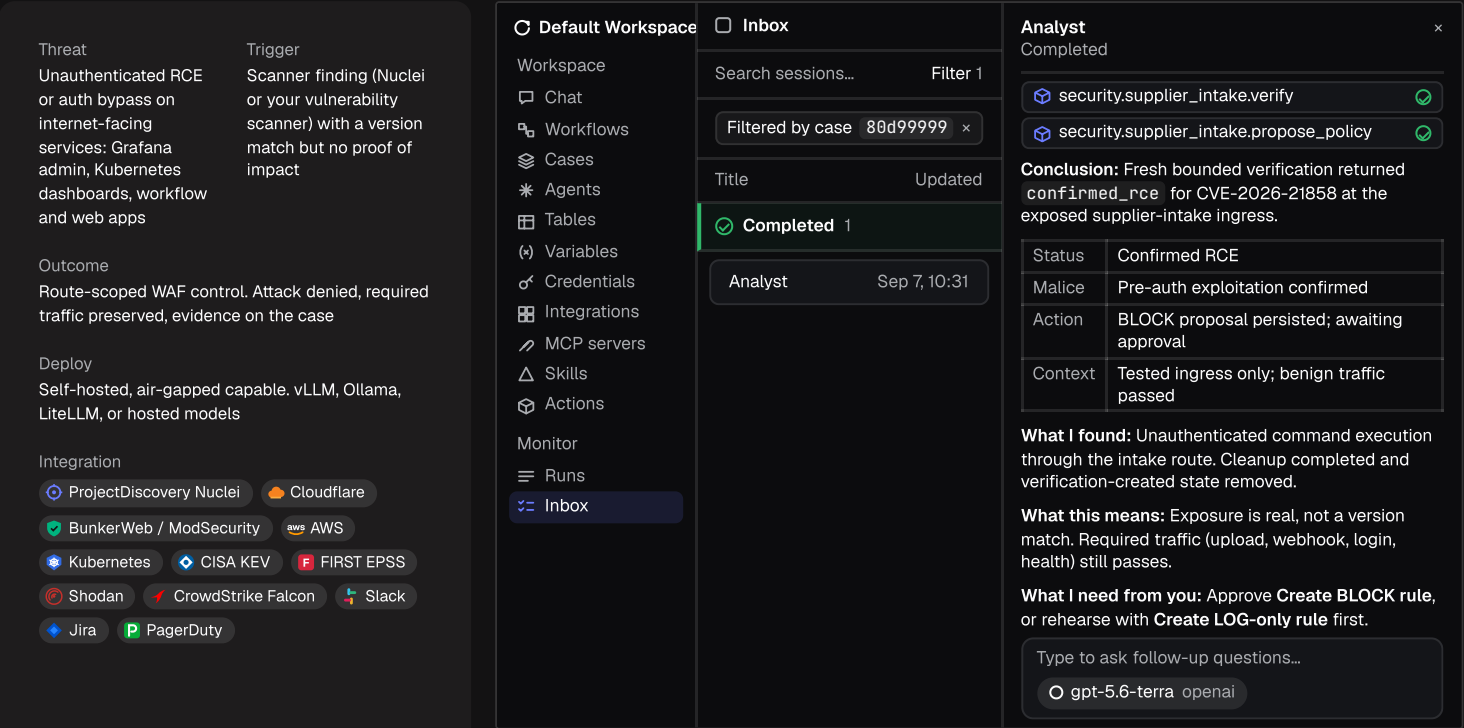


Figure 1. The Analyst session in the Inbox after fixed-target verification: sanitised evidence, a route-scoped BLOCK proposal, one decision for one human.

Key highlights

< 2 minutes
Scanner signal to a verified, retested control; full loop measured at 78–102 s, 15 of 15 acceptance gates.

0 credentials
Firewall credentials or free-form rule syntax exposed to the agent, which can propose but never apply.

100% preserved
Required traffic preserved: upload, webhook, login, and health are retested on every apply.

1 click
Human approval applies the exact reviewed rule, verifies activation, and rolls back on failure.

Same day
Exposure window per finding, versus a 55–61 day industry patch MTTR (Edgescan; modeled).

The problem

Discovery has gone machine-scale. Anthropic's Project Glasswing (Claude Mythos, Apr–May 2026) reported 23,019 issues across 1,000+ open-source projects, 10,000+ of them high or critical, and more than 99% unpatched at disclosure. OpenAI's GPT-6 Astra (Sep 3, 2026) is the first model rated "Critical" for cyber under its Preparedness Framework, and found and exploited two zero-days unaided. Open-weight Z.ai GLM-5.3 claims 2,436 findings across 269 projects and 105 of 130 ExploitGym targets, and anyone, including attackers, can run it.

The zero-day clock is negative. Mandiant/GTIG time-to-exploit fell from 63 days (2018–19) to 5 days (2023), then to about –1 day (2024) and about –7 days (2025). VulnCheck's 1H-2026 data shows 23% of KEVs exploited on or before CVE publication. Defender patch MTTR is still 55–61 days, and about 60% of breaches involve a vulnerability with a patch already available.

Where teams get stuck. Vulnerability management receives thousands of version-match findings and cannot tell exploitable from noise. Patching waits on owners and change windows. A hand-written WAF rule is risky (a global JSON or POST block breaks the business), so nobody writes one, and the finding sits open. Every hour is exposure.

The solution

An Analyst agent that verifies, proposes, and hands the decision to a human.

Tracecat runs an Analyst agent against each finding. The preset is case-scoped, has no internet access, and holds no firewall credential: it proves or disproves exploitability, then writes a narrow, reviewable control for a person to approve. Its tools are bounded Python actions with pinned dependencies (scan , verify , propose_policy), never free-form rule syntax; apply_reviewed_policy , which holds the WAF and app secrets, exists only inside the workflow a human launches (Figure 2, next page).

1. **Finding.** A scanner hit or KEV/EPSS feed opens a case.
2. **Verify.** scan and verify run against a fixed target and return sanitised evidence only, with one of five verdicts: confirmed_rce, blocked_by_waf, not_reproduced, inconclusive, or confirmed_file_read.
3. **Propose.** An immutable, revision-bound, route-scoped policy (route, POST, allowed content-type; BLOCK or LOG_ONLY) with rationale and rollback is written to the case.
4. **Approve.** One case task: Create BLOCK rule, or Create LOG-only rule to rehearse first (Figure 3, next page).
5. **Apply.** A human-launched workflow applies the exact reviewed proposal, verifies activation, retests upload, webhook, login, and health, and rolls back on failure.
6. **Close.** The agent posts the before/after verdict, correlated firewall events, and remaining patch risk.

The preset, its two skills, and the hosted MCP servers it can be given are all first-class objects in the workspace (Figures 4–6, page 3).

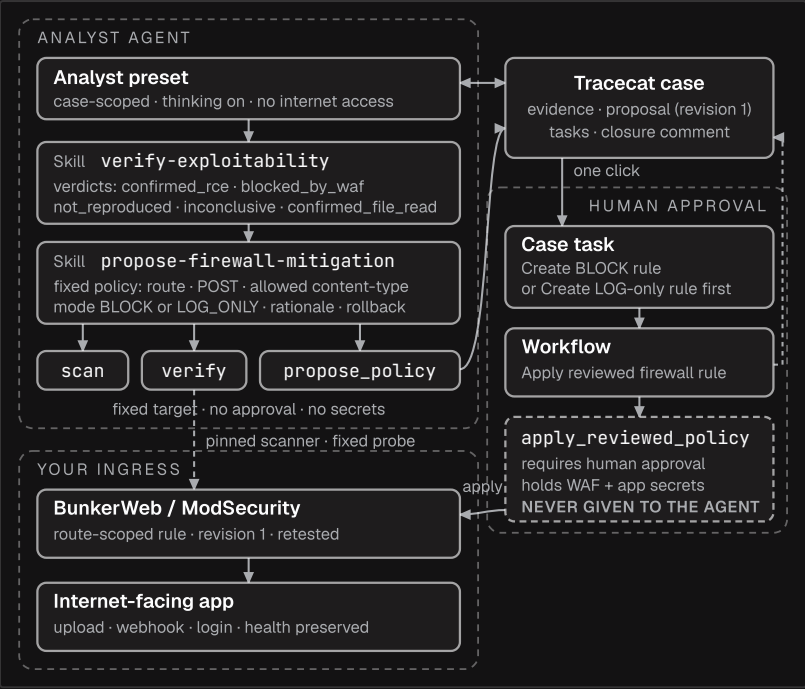


Figure 2. What the Analyst preset can use, and the one action it cannot.

INPUTS		OUTPUTS	
Internet-facing high/critical findings needing exploitability triage	30 / month	Analyst hours returned each month	165 h
Manual path per finding validate 2h · author and test a compatible WAF rule 3h · retest and document 1h	≈ 6 h	Value of returned analyst time	≈ \$20.6k / month ≈ \$248k / year
Tracecat path per finding review evidence · approve · read the closure	≈ 0.5 h	Exposure window per finding	55–61 days → same shift
Loaded analyst cost	\$125 / h	Acceptance checks on every apply	15 automated

Not counted: breach-cost avoidance (IBM Cost of a Data Breach 2025, global average \$4.44M per incident).

The results

< 2 minutes from scanner signal to a verified, retested control

The full loop measured at 78–102 s in Tracecat's reference environment, passing 15 of 15 acceptance gates on every apply.

0 firewall credentials exposed to the agent

The agent can propose but never apply. The credential and the rule syntax live only in the human-approved workflow.

100% of required traffic preserved

Upload, webhook, login, and health are retested after every apply; a failed retest rolls the rule back automatically.

165 analyst-hours returned per month,
≈\$20.6k/month, ≈\$248k/year (modeled)

A modeled month for one team. Every input is an assumption; swap in your own volumes, hours, and rates. The control is mitigation at the tested ingress, not a patch.

Cases / CASE-0001

15 minutes ago · Less than a minute ago

* View agent runs

1/2

Suspected unauthenticated RCE on supplier intake

No tags

Create BLOCK rule

Create LOG-only rule

Add task

Apply reviewed fi...

Apply reviewed fi...

Tracecat

I'm validating whether this scanner finding has real impact at the exposed ingress.

Leave a reply...

Tracecat

I confirmed unauthenticated command execution through the supplier intake route.

Status	Malice	Action	Context
Confirmed RCE	Active verification confirmed unauthenticated execution; cleanup completed	Review a route-scoped control recommendation	Supplier intake ingress; no firewall control applied

What I found

- Fresh scanning retained the vulnerable-version signal.
- Active verification confirmed command execution at the exposed supplier intake ingress.
- Required benign application traffic passed, and verification cleanup completed.

Properties

Status

Priority

Severity

Assignee

New

High

Critical

Unassigned

Fields

No custom fields configured

Figure 3. The case at the approval moment: two tasks for the human, and the agent's verification evidence beneath.

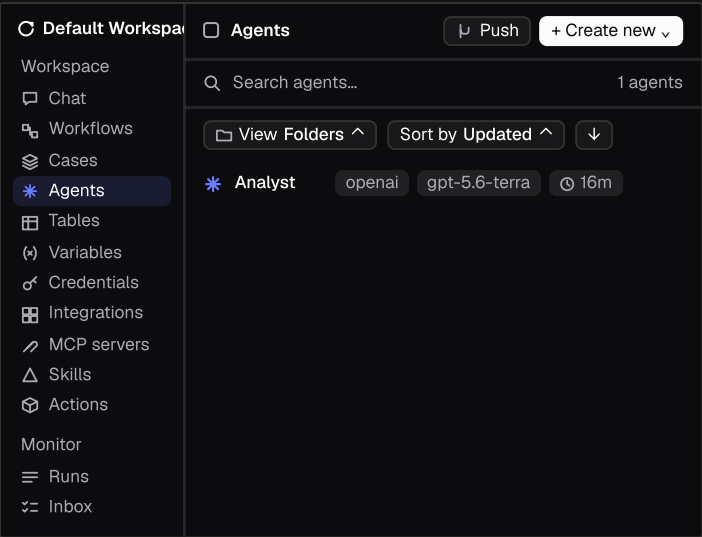


Figure 4. Agents: the Analyst preset, pinned to a model and provider, with its tool policy and skills attached.

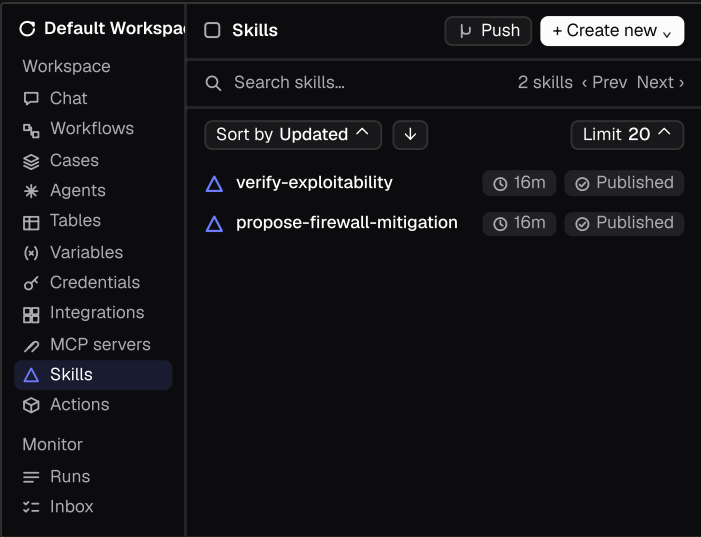


Figure 5. Skills: the two versioned, reviewed procedures the Analyst runs, published to the workspace and pushed to Git.

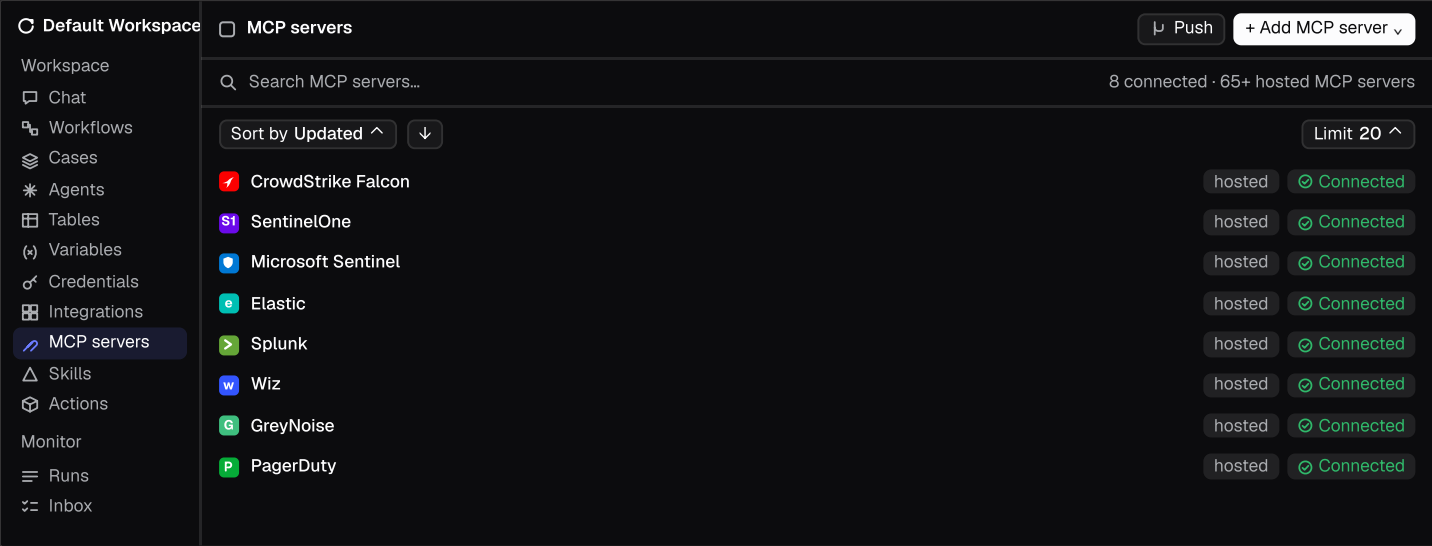


Figure 6. MCP servers: 65+ hosted servers (EDR, SIEM, cloud, threat intel, paging) that can be attached to an agent without writing integration code. Eight shown.

“A genuine thank you to the team. I built an end-to-end IoC enrichment pipeline with Claude and Tracecat MCP and created more value for our SOC in a day than I probably would have in weeks on my own. You’re making my one-man SOC assignment possible.”

Senior Security Engineer, Neo Financial

Why Tracecat

Your network, your models.

Self-host in your VPC, on-prem, or fully air-gapped on Kubernetes. Point agents at vLLM or Ollama, directly or via LiteLLM. Evidence never leaves your boundary.

Integrations in an afternoon.

Any WAF, scanner, or ticketing system becomes an agent tool via a Python file or YAML template (500+ integrations, 65+ hosted MCP servers). Tracecat MCP turns a Claude Code, Codex, or Cursor prompt into workflows, tasks, and skills.

Bounded tools, not a shell.

Fixed-target Python actions with pinned dependencies, default-deny tool policy, sandboxing, full audit log. The agent never holds the firewall credential or rule syntax.

Analysts stay in command.

Immutable, revision-bound proposals, one-click approval, automatic rollback, LOG-only rehearsal. Skills and memory are versioned and reviewed. Open source under AGPL v3.0, so the operating model is inspectable.

Talk to a Tracecat expert

Discuss your exposed services, scanner feeds, WAF estate, and approval requirements with the Tracecat team.

Book a demo

tracecat.com/contact →

tracecat.com docs.tracecat.com github.com/TracecatHQ/tracecat

Sources. Anthropic, Project Glasswing update (May 26, 2026) · OpenAI, GPT-6 Astra announcement (Sep 3, 2026) · Z.ai, GLM-5.3 release · Mandiant / Google Threat Intelligence Group, time-to-exploit analyses · VulnCheck, 1H-2026 exploitation report · Edgescan, vulnerability statistics (patch MTTR) · IBM, Cost of a Data Breach Report 2025. Loop timings and gate counts are from Tracecat’s reference environment for this scenario. Every Tracecat feature works offline; see docs.tracecat.com/self-hosting/air-gapped.